

# QUESTIONARIO DI PROGETTAZIONE

# Sistema di segnalazioni anonime

---

Dubbi e decisioni da chiarire prima della specifica di sicurezza v0.1

Versione 0.1 — 24 agosto 2026

## Come usarlo

- Scrivi la tua risposta direttamente sotto ogni domanda, nella riga "RISPOSTA:".
- Se una domanda non è chiara, scrivi semplicemente "NON CHIARO". La riprenderemo insieme senza assumere una risposta.
- Se non hai ancora una preferenza, scrivi "DA DECIDERE".
- Le domande CRITICHE possono cambiare l'architettura di sicurezza; le ALTE definiscono il comportamento operativo; le MEDIE possono essere definite subito dopo.

**Questo documento riguarda solo la base approvata. Non introduce chat, aggregazione delle segnalazioni, analytics, classifiche, funzioni future o sistemi di autenticazione del segnalante.**

# A. Decisioni già approvate

Questi punti sono considerati baseline. Non serve rispondere salvo che tu voglia correggerne uno.

| Punto              | Decisione approvata                                                                                                                                          |
|--------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Scopo              | Ricevere una segnalazione anonima, consentire una sola risposta dell'operatore e permettere al segnalante di recuperare quella risposta senza conversazione. |
| Segnalante         | Nessun account, login, email, telefono o autenticazione obbligatoria.                                                                                        |
| Modulo             | Un solo box di testo a lunghezza limitata; nessuna domanda guidata.                                                                                          |
| Allegati           | Solo PDF e immagini, con numero e dimensione massima da definire.                                                                                            |
| Anti-bot           | CAPTCHA/privacy challenge self-hosted; niente Google reCAPTCHA e niente dipendenza da servizi terzi di tracking.                                             |
| Recupero           | Accesso alla Response Note tramite segreto non indovinabile; niente identificatori sequenziali utilizzati come credenziale.                                  |
| Response Note      | Contiene esclusivamente il testo della risposta. Nessuna chat, cronologia, replica o metadato visibile aggiuntivo.                                           |
| Priorità           | Massima priorità alla riservatezza del contenuto della segnalazione e degli allegati.                                                                        |
| Accesso operatore  | La segnalazione non deve essere normalmente consultabile più volte: esiste una sola sessione ordinaria di lavorazione.                                       |
| Riapertura         | Una riapertura dopo interruzione involontaria è eccezionale e richiede motivazione tracciata.                                                                |
| Audit              | Gli accessi dell'operatore devono essere loggati senza registrare il contenuto della segnalazione nei log.                                                   |
| Cancellazione      | Dopo l'invio della risposta, segnalazione e allegati devono diventare irrecuperabili.                                                                        |
| Export d'emergenza | Deve esistere una procedura guidata, eccezionale e tracciata per preservare/esportare tutte le informazioni ricevute in casi delicati.                       |
| Decision support   | Può essere studiato concettualmente, ma i percorsi reali dovranno essere definiti con professionisti competenti; non fa parte della base tecnica attuale.    |
| Terze parti        | La superficie del segnalante deve evitare risorse e servizi esterni non necessari; l'obiettivo è una catena il più possibile self-hosted.                    |

## Sezioni da compilare

1. Avversari e livello di protezione richiesto
2. Modalità di pubblicazione e anonimato di rete
3. Dati accettati dal modulo
4. CAPTCHA e resistenza agli abusi
5. Segreto di recupero e accesso alla risposta
6. Operatore: autenticazione, presa in carico e singola sessione
7. Interruzioni e riaperture eccezionali
8. Visualizzazione sicura di testo e allegati

9. Audit log e responsabilità degli accessi
10. Cifratura, chiavi, storage, cancellazione e backup
11. Response Note
12. Export d'emergenza e integrità del materiale
13. Tempi di conservazione e casi non conclusi
14. Ambiente operativo e amministrazione del sistema

# 1. Avversari e livello di protezione richiesto

Qui definiamo contro chi il sistema deve continuare a proteggere il contenuto. Se una voce non ti è chiara, scrivi NON CHIARO.

## 1. [CRITICA] Dobbiamo proteggere il contenuto anche da un normale amministratore del server?

Perché serve chiarirlo: Se la risposta è sì, l'amministratore che gestisce sistema operativo/database non deve possedere da solo ciò che serve per decifrare i report.

**Indicazione tecnica attuale:** Io tenderei a SÌ, almeno come obiettivo architetturale.

**RISPOSTA: SI**, in linea generale anche l'amministratore deve essere considerato "da controllare" ma è chiaro che deve poter avere gli strumenti per agire ed intervenire in caso di problematiche.

## 2. [CRITICA] Dobbiamo proteggere il contenuto anche da un amministratore del database che ottiene una copia completa del DB?

Perché serve chiarirlo: Stabilisce se la cifratura deve essere applicativa e separata dal database, non solo "disco cifrato".

**Indicazione tecnica attuale:** Consiglio SÌ.

**RISPOSTA: SI**, come per il punto 1.

## 3. [CRITICA] Dobbiamo proteggere il contenuto anche se viene rubato o copiato lo storage degli allegati?

Perché serve chiarirlo: PDF e immagini non devono diventare leggibili semplicemente copiando il filesystem/object storage.

**Indicazione tecnica attuale:** Consiglio SÌ.

**RISPOSTA: SI**

## 4. [CRITICA] Dobbiamo cercare di proteggere i report anche in caso di compromissione completa del server applicativo mentre i report sono ancora SEALED?

Perché serve chiarirlo: È uno scenario molto più difficile: un attaccante con privilegi elevati può tentare di sottrarre chiavi o modificare il software.

**Indicazione tecnica attuale:** Se vuoi una protezione forte anche qui, servirà separare maggiormente il servizio di chiavi/decriptazione dal server web.

**RISPOSTA: SI**

## 5. [CRITICA] Un operatore autorizzato ma curioso/malevolo deve essere considerato un avversario?

Perché serve chiarirlo: Decide quanto dobbiamo limitare riaperture, copie, download e accessi non necessari anche per chi ha credenziali valide.

**Indicazione tecnica attuale:** Dalle tue indicazioni attuali direi SÌ.

**RISPOSTA: SI**

## 6. [ALTA] Dobbiamo proteggere il contenuto da un secondo operatore che non ha preso in carico quel ticket?

Perché serve chiarirlo: Serve a definire isolamento tra operatori e assegnazione esclusiva.

**Indicazione tecnica attuale:** Consiglio SÌ: un solo operatore deve possedere l'accesso ordinario al report.

**RISPOSTA: SÌ:** un solo operatore deve possedere l'accesso ordinario al report.

**7. [ALTA] Accettiamo che un computer dell'operatore già compromesso da malware possa leggere ciò che l'operatore vede?**

*Perché serve chiarirlo: Nessuna web app può impedire a malware con controllo del dispositivo di fotografare lo schermo o leggere la memoria. Possiamo solo ridurre il rischio con postazioni dedicate/hardening.*

**Indicazione tecnica attuale: Se vuoi protezione anche da questo scenario, bisognerà imporre requisiti forti sulle postazioni operatori.**

**RISPOSTA: NO, dobbiamo assumere che le postazioni che accedono siano sicure. Saranno postazioni esclusive e dedicate.**

.....

**8. [MEDIA] Accettiamo che un segnalante con dispositivo compromesso non possa essere protetto dal sistema?**

*Perché serve chiarirlo: Se il dispositivo del segnalante contiene malware/keylogger, il codice di recupero e il testo possono essere rubati prima della cifratura.*

**Indicazione tecnica attuale: Normalmente questo rischio viene dichiarato fuori dal perimetro, pur fornendo raccomandazioni di sicurezza.**

**RISPOSTA: Non voglio implementare meccanismi di sicurezza in merito, bensì nei termini e condizioni della piattaforma specificheremo che non possiamo avere la certezza che il dispositivo dal quale viene inviata la segnalazione sia privo di malware e che in quel caso potrebbe comportare il rischio di un leak del segreto per accedere alla risposta.**

.....

**9. [CRITICA] La disponibilità del servizio può essere sacrificata pur di non indebolire la riservatezza?**

*Perché serve chiarirlo: Esempio: se il servizio di chiavi non è disponibile, è meglio non aprire nessun ticket oppure prevedere una modalità di emergenza meno sicura?*

**Indicazione tecnica attuale: Consiglio fail-closed: se la protezione non è disponibile, il contenuto resta inaccessibile.**

**RISPOSTA: se la protezione non è disponibile, il contenuto resta inaccessibile. Dobbiamo garantire il corretto funzionamento dei sistemi di riservatezza al pieno delle loro potenzialità.**

.....

## **2. Modalità di pubblicazione e anonimato di rete**

**10. [CRITICA] Il progetto deve offrire obbligatoriamente un Onion Service Tor?**

*Perché serve chiarirlo: Solo così possiamo offrire un canale in cui il server non vede l'IP reale del segnalante.*

**Indicazione tecnica attuale: Consiglio SÌ se vogliamo usare seriamente il termine "anonimo".**

**RISPOSTA: Sì e non solo, sul sito con classico dominio deve essere presente un popup che incita l'utente ad utilizzare Tor anziché il servizio normale.**

.....

**11. [CRITICA] Vuoi consentire anche un normale sito HTTPS oltre all'Onion Service?**

*Perché serve chiarirlo: Con HTTPS il contenuto è cifrato in transito, ma l'infrastruttura di rete può osservare l'IP. Non è equivalente a Tor.*

**Indicazione tecnica attuale: Possibile soluzione: entrambi, ma descritti con livelli di privacy diversi.**

**RISPOSTA: SÌ devono coesistere i due siti.**

.....

**12. [CRITICA] Se esiste la versione HTTPS, il sistema deve comunque evitare totalmente di memorizzare IP e User-Agent?**

*Perché serve chiarirlo: Reverse proxy e web server spesso registrano automaticamente questi dati.*

**Indicazione tecnica attuale: Consiglio SÌ: access log disabilitati o rigorosamente minimizzati sul lato segnalante.**

**RISPOSTA: SÌ, il sito deve impegnarsi a non acquisire questo genere di dati. Access log disabilitati o rigorosamente minimizzati sul lato segnalante.**

### 13. [ALTA] Possiamo imporre JavaScript al segnalante?

*Perché serve chiarirlo: Il CAPTCHA proof-of-work e una eventuale cifratura client-side richiedono JavaScript; Tor Browser può essere configurato per limitarlo.*

**Indicazione tecnica attuale: Se JavaScript è necessario, dovremo ridurlo al minimo e servirlo tutto localmente.**

**RISPOSTA: JavaScript deve essere escluso tutte le volte che può essere escluso. Se è necessario per il captcha e non esistono alternative valide allora lo integreremo. Dobbiamo pensare ad una soluzione per TorBrowser che di default disabilita javascript.**

### 14. [ALTA] La pagina deve funzionare anche con il livello di sicurezza "Safest" di Tor Browser, dove JavaScript può essere disabilitato?

*Perché serve chiarirlo: Se dici SÌ, alcune scelte attuali come ALTCHA e cifratura nel browser vanno ripensate o serve un percorso alternativo.*

**RISPOSTA: Come dicevo nella risposta 13 se il captcha non è utilizzabile senza javascript allora dobbiamo pensare ad una soluzione che ci permetta di mantenere il livello di sicurezza anti-bot alto.**

### 15. [CRITICA] Confermi il divieto di qualsiasi risorsa remota sul frontend del segnalante (font, CDN, analytics, error tracking cloud, widget)?

*Perché serve chiarirlo: Una singola richiesta a terzi può creare metadata non controllati dal progetto.*

**Indicazione tecnica attuale: Consiglio SÌ: tutto self-hosted e CSP molto restrittiva.**

**RISPOSTA: SÌ: tutto self-hosted e CSP molto restrittiva.**

## 3. Dati accettati dal modulo

### 16. [MEDIA] Quale limite massimo vuoi per il testo della segnalazione?

*Perché serve chiarirlo: Serve per prevenire abuso e dimensionare storage/processing. Possiamo scegliere un valore semplice e sufficientemente ampio.*

**Indicazione tecnica attuale: Esempi ragionevoli: 5.000 o 10.000 caratteri.**

**RISPOSTA: 5.000 caratteri**

### 17. [ALTA] Quanti allegati massimi deve poter inviare una singola segnalazione?

*Perché serve chiarirlo: Un limite impedisce abusi e storage exhaustion senza richiedere identificazione del mittente.*

**RISPOSTA: Massimo 1 documento pdf e/o 3 immagini.**

### 18. [ALTA] Quale dimensione massima per singolo allegato e quale dimensione massima complessiva per ticket?

*Perché serve chiarirlo: Il controllo deve avvenire lato server prima di processare file troppo grandi.*

**RISPOSTA: Il documento pdf consentito deve pesare massimo 5MB e le immagini devono pesare massimo 5MB l'una.**

#### 19. [ALTA] Confermi i soli formati PDF, JPEG e PNG?

*Perché serve chiarirlo: Una allowlist corta riduce molto la superficie di attacco dei parser.*

**Indicazione tecnica attuale:** *Consiglio di non accettare DOCX, ZIP, video o formati attivi nella baseline.*

**RISPOSTA:** Confermo di voler accettare solo PDF, JPEG e PNG

.....

#### 20. [CRITICA] Gli originali devono essere conservati byte-per-byte fino alla risposta, anche se contengono metadata identificativi?

*Perché serve chiarirlo: Rimuovere metadata aumenta privacy ma può distruggere informazioni che in alcuni casi sono prova. Per l'export d'emergenza l'originale potrebbe essere importante.*

**Indicazione tecnica attuale:** *Io tenderei a preservare l'originale cifrato e a non modificarlo automaticamente.*

**RISPOSTA:** Gli allegati devono essere preservati così come vengono inviati con tanto di metadata, non devono essere alterati. All'interno del sito avremo dei piccoli articoli che spiegano come ottimizzare l'anonimato durante l'invio di una segnalazione come ad esempio eliminando i metadata dagli allegati.

.....

#### 21. [ALTA] L'operatore deve vedere il nome originale del file caricato?

*Perché serve chiarirlo: Un filename può contenere nome/cognome o altre informazioni identificative. Nascondere lo tutela il segnalante, ma può rimuovere contesto utile.*

**RISPOSTA:** Il file dovrà subire alcuni controlli e adeguamenti di sicurezza. Tra questi sicuramente deve essere prevista la rinominazione del file. I file allegati devono essere rinominati utilizzando esclusivamente lettere escludendo completamente qualunque altro tipo di carattere. Dopo il caricamento il nome verrà modificato con una stringa casuale uuid.

.....

#### 22. [CRITICA] PDF con JavaScript, allegati incorporati, moduli attivi o contenuti anomali devono essere rifiutati oppure resi visualizzabili tramite una rappresentazione sicura?

*Perché serve chiarirlo: I PDF sono documenti complessi e possono contenere elementi attivi; aprirli direttamente nel browser/lettore aumenta il rischio.*

**Indicazione tecnica attuale:** *Consiglio di non eseguire mai contenuto attivo e di usare una visualizzazione isolata/sanitizzata, preservando comunque l'originale cifrato.*

**RISPOSTA:** L'aspetto di sicurezza informatica è il più importante tra tutti quindi qualunque genere di allegato dinamico o che contiene elementi che anche solo potrebbero essere in qualche modo dinamici devono essere scartati. Dobbiamo accettare esclusivamente allegati statici e sicuri.

.....

## 4. CAPTCHA e resistenza agli abusi

#### 23. [CRITICA] Confermi che il CAPTCHA deve essere completamente self-hosted e senza richieste a infrastrutture di terzi?

*Perché serve chiarirlo: È il requisito che esclude reCAPTCHA e servizi analoghi dal percorso del segnalante.*

**Indicazione tecnica attuale:** *SÌ implica che challenge e verifica avvengono sul nostro server.*

**RISPOSTA:** SÌ implica che challenge e verifica avvengono sul nostro server.

.....

#### 24. [ALTA] Accetti un CAPTCHA proof-of-work come ALTCHA, che rende costoso l'automatismo ma non "riconosce" una persona?

*Perché serve chiarirlo: È più privacy-friendly di sistemi di fingerprinting, ma non impedisce in assoluto a un attaccante determinato di inviare spam.*

**Indicazione tecnica attuale:** Attualmente è la scelta che preferisco per la baseline.

**RISPOSTA:** Attualmente è la scelta che preferisco per la baseline.

.....

**25. [MEDIA] La challenge CAPTCHA deve essere obbligatoria anche quando il segnalante controlla la Response Note?**

*Perché serve chiarirlo: Il recovery secret a 256 bit è già impraticabile da indovinare; il CAPTCHA sul check può però limitare traffico abusivo/DoS.*

**RISPOSTA:** Sì.

.....

**26. [ALTA] In caso di attacco massivo, accetti un limite globale temporaneo del numero di nuove submission, senza identificare utenti/IP?**

*Perché serve chiarirlo: Senza identità non possiamo fare rate limit per persona; possiamo solo proteggere la capacità globale del servizio.*

**RISPOSTA:** Sì

.....

## 5. Segreto di recupero e accesso alla risposta

**27. [CRITICA] Preferisci un unico segreto lungo oppure una coppia "ID pubblico del ticket + segreto privato"?**

*Perché serve chiarirlo: Separare lookup e autenticazione può semplificare il DB e ridurre il rischio di trattare l'identificatore come credenziale. Entrambe le soluzioni possono essere sicure se progettate bene.*

**Indicazione tecnica attuale:** La parte segreta deve comunque avere elevata entropia e non essere derivata dall'ID.

**RISPOSTA:** Preferisco mantenerli separati come "ID pubblico del ticket + segreto privato"

.....

**28. [CRITICA] Il segreto deve essere generato nel browser del segnalante o dal server?**

*Perché serve chiarirlo: Se generato nel browser, il server può essere progettato per non conoscere mai il segreto in chiaro dopo la creazione; richiede però JavaScript affidabile.*

**Indicazione tecnica attuale:** Preferenza tecnica: generazione client-side con CSPRNG, se accettiamo JavaScript.

**RISPOSTA:** Da valutare. Non credo che il sistema di sicurezza principale debba essere demandato client-side, ma potremmo comunque generare un meccanismo di comunicazione sicura tra client e server che ci permetta di accettarlo. In linea generale dovremmo capire qual è la best practice in questo genere di contesto.

.....

**29. [ALTA] Il codice deve essere facile da trascrivere a mano oppure possiamo privilegiare una stringa lunga da copiare/salvare?**

*Perché serve chiarirlo: Un formato "umano" riduce errori ma può ridurre entropia se progettato male. Possiamo mantenere 256 bit anche con encoding opportuno, ma il codice diventa lungo.*

**RISPOSTA:** Il codice non deve essere facile da trascrivere. Deve essere una stringa casuale che l'utente dovrà salvare manualmente ma non deve poter essere ricordabile o facile da trascrivere.

.....

**30. [CRITICA] Vuoi che il sistema mostri il segreto una sola volta dopo l'invio, senza poterlo recuperare successivamente?**

*Perché serve chiarirlo: È la scelta più coerente con un modello capability-based: chi perde il segreto perde l'accesso.*

**Indicazione tecnica attuale:** Consiglio SÌ.



**RISPOSTA: SÌ** e non deve poter essere recuperato tramite cronologia web o andando in dietro nelle pagine. Dobbiamo assicurarci che l'utente abbia un solo evento/momento per poter acquisire quel dato.

.....

**31. [CRITICA] La Response Note deve poter essere letta più volte dal segnalante oppure una sola volta?**

*Perché serve chiarirlo: Hai richiesto accesso singolo per l'operatore, ma non abbiamo ancora stabilito il comportamento della risposta lato segnalante.*

**RISPOSTA: La Response Note deve poter essere aperta più volte.**

.....

**32. [CRITICA] Se la Response Note viene letta una sola volta, deve essere eliminata subito dopo la prima lettura riuscita?**

*Perché serve chiarirlo: Riduce la permanenza dei dati, ma aumenta il rischio che l'utente chiuda accidentalmente la pagina e perda definitivamente la risposta.*

**RISPOSTA: Da quando l'utente apre per la prima volta la Response Note allora, la stessa, deve esistere per i successivi 3 giorni oltre i quali deve essere automaticamente eliminata in maniera definitiva.**

.....

**33. [ALTA] Il segreto di recupero deve avere una scadenza?**

*Perché serve chiarirlo: Senza scadenza la risposta potrebbe rimanere conservata indefinitamente; con scadenza dobbiamo definire un periodo ragionevole.*

**RISPOSTA: Il segreto di recupero deve essere non più utilizzabile in nessun caso. Utilizzando sha-256 possiamo evitare di porci il problema di dover riutilizzare codici.**

.....

**34. [CRITICA] Un tentativo con codice inesistente deve restituire una risposta indistinguibile da un ticket esistente ma non ancora risposto?**

*Perché serve chiarirlo: Evita che un attaccante possa enumerare l'esistenza di ticket attraverso differenze nel messaggio o nei tempi.*

**Indicazione tecnica attuale: Consiglio SÌ: messaggi e timing il più possibile uniformi.**

**RISPOSTA: Assolutamente sì. Messaggi di errore di qualunque genere e timing di risposta devono essere il più possibili uniformi per evitare possibili compromissioni basate sull'interpretazione di questi dati.**

.....

## **6. Operatore: autenticazione, presa in carico e singola sessione**

**35. [CRITICA] Vuoi escludere l'accesso operatore con sola password e richiedere sempre una seconda prova forte (passkey/FIDO2/security key)?**

*Perché serve chiarirlo: Chi ottiene una credenziale operatore può leggere il contenuto più sensibile del sistema.*

**Indicazione tecnica attuale: Consiglio SÌ: autenticazione phishing-resistant dove possibile.**

**RISPOSTA: Sì, la doppia autenticazione deve essere obbligatoria per l'operatore e la gestione delle chiavi di sessione deve avvenire in maniera sicura secondo quanto richiesto dalle best practice in merito.**

.....

**36. [ALTA] Un operatore può avere più di un ticket contemporaneamente CLAIMED/OPEN?**

*Perché serve chiarirlo: Consentirlo aumenta efficienza ma indebolisce il principio "apro solo se posso completare".*

**Indicazione tecnica attuale:** *Io proporrei un solo ticket attivo per operatore nella baseline.*

**RISPOSTA:** No, un operatore deve poter aprire un solo ticket per volta per evitare che possa averne dimenticato uno aperto.

**37. [CRITICA] La presa in carico deve avvenire prima che l'operatore possa vedere anche una sola parola del contenuto?**

*Perché serve chiarirlo: Serve a rendere significativo il log e l'impegno a completare il ticket.*

**Indicazione tecnica attuale:** *Consiglio SÌ.*

**RISPOSTA:** Si

**38. [ALTA] Dopo il claim, quanto tempo può passare prima dell'apertura effettiva?**

*Perché serve chiarirlo: Un operatore potrebbe "prenotare" un ticket e bloccarlo senza lavorarlo.*

**RISPOSTA:** 15 minuti massimo

**39. [CRITICA] La sessione OPEN deve avere una durata massima assoluta?**

*Perché serve chiarirlo: Impedisce che una scheda resti aperta per ore o giorni.*

**Indicazione tecnica attuale:** *Possibile combinazione: timeout di inattività + durata massima.*

**RISPOSTA:** No

**40. [CRITICA] La sessione deve bloccarsi automaticamente dopo un periodo di inattività?**

*Perché serve chiarirlo: Riduce il rischio di monitor lasciati incustoditi e sessioni dimenticate.*

**RISPOSTA:** La sessione deve avere un tempo limitato

**41. [CRITICA] Il semplice refresh della pagina deve essere considerato una riapertura eccezionale?**

*Perché serve chiarirlo: Se la chiave viene concessa una sola volta per sessione, dobbiamo decidere se il refresh appartiene alla stessa sessione o ne crea una nuova.*

**Indicazione tecnica attuale:** *Preferirei trattare refresh/navigazione nella stessa lease attiva come stessa sessione, evitando falsi incidenti; dopo perdita della lease serve riapertura motivata.*

**RISPOSTA:** No, se la chiave di sessione è ancora valida allora può non essere considerata una riapertura.

**42. [ALTA] L'operatore che ha aperto il ticket deve essere l'unico autorizzato a scrivere e inviare la risposta?**

*Perché serve chiarirlo: Evita passaggi di contenuto tra operatori e mantiene chiara la responsabilità.*

**Indicazione tecnica attuale:** *Consiglio SÌ salvo procedura eccezionale da definire.*

**RISPOSTA:** No, i ticket possono essere riaperti da altri operatori.

**43. [CRITICA] L'invio della risposta deve essere un'azione irreversibile con conferma esplicita?**

*Perché serve chiarirlo: Da quel momento distruggeremo la chiave/contenuto originale, quindi un errore non sarebbe recuperabile.*

**Indicazione tecnica attuale:** *Consiglio una schermata di conferma finale che non mostri di nuovo la segnalazione.*

**RISPOSTA:** Sì, l'invio della risposta deve essere irreversibile e deve esserci un controllo con captcha all'invio.

## 7. Interruzioni e riaperture eccezionali

### 44. [CRITICA] Confermi che una riapertura dopo perdita della sessione richiede sempre una motivazione testuale obbligatoria?

*Perché serve chiarirlo: È la tua regola principale per distinguere un incidente da una consultazione ripetuta.*

**Indicazione tecnica attuale:** Attualmente la considero approvata; qui puoi specificare eventuali eccezioni.

**RISPOSTA:** Sì. Devi considerare che un singolo ticket può essere riaperto più volte, l'importante è che l'operatore che lo riapre scrive perché lo sta riaprendo e perché fin ora non è stato evaso. Considera che ogni messaggio deve essere salvato su quella che dovrà essere la cronologia della segnalazione e quindi ogni operazione deve essere loggata così come viene loggata la riapertura del ticket. Chiaramente se un operatore Alice apre un ticket, in un secondo momento l'apertura del ticket sarà la seconda volta se continua ad essere Alice ad aprirlo mentre sarà la prima volta se lo aprirà Bob. Chiaramente è necessario gestire il lock per l'apertura e la gestione dei ticket per evitare errori di sovrapposizione delle risposte e delle risorse tipo race condition.

### 45. [CRITICA] La riapertura può essere autorizzata dallo stesso operatore inserendo il motivo, oppure deve richiedere anche l'approvazione di un secondo soggetto/supervisore?

*Perché serve chiarirlo: La prima opzione è semplice; la seconda protegge meglio da abusi dell'operatore ma introduce ritardi e organizzazione.*

**RISPOSTA:** La riapertura non necessita un'autorizzazione.

### 46. [ALTA] Vuoi un limite massimo al numero di riaperture eccezionali?

*Perché serve chiarirlo: Un limite rigido può bloccare casi reali con più incidenti; nessun limite può essere abusato. Il log comunque rende ogni evento visibile.*

**RISPOSTA:** No

### 47. [ALTA] Dopo una riapertura, deve essere richiesta nuovamente autenticazione forte anche se la sessione operatore è ancora autenticata?

*Perché serve chiarirlo: È una forma di step-up authentication specifica per un'azione eccezionale.*

**Indicazione tecnica attuale:** Consiglio SÌ.

**RISPOSTA:** No

### 48. [ALTA] La motivazione di riapertura può essere testo libero oppure preferisci una causa selezionabile + nota libera?

*Perché serve chiarirlo: Testo libero è flessibile ma rischia che l'operatore inserisca dettagli sensibili della segnalazione nei log.*

**Indicazione tecnica attuale:** Suggerirei causa standard + breve motivazione, con avviso "non inserire contenuto del report".

**RISPOSTA:** Una breve nota arbitraria di massimo 150 caratteri con avviso "non inserire contenuto del report".

### 49. [ALTA] Chi deve poter leggere le motivazioni di riapertura e i relativi audit log?

*Perché serve chiarirlo: Serve accountability senza allargare inutilmente l'accesso ai dati operativi.*

**RISPOSTA:** Le motivazioni di riapertura devono essere riportate nella funzionalità di esportazione straordinaria. Per adesso non è prevista una figura che controlla gli operatori ma sicuramente verrà integrata in futuro quindi per adesso conserva le evidenze normalmente finché esiste il ticket.

.....

## 8. Visualizzazione sicura di testo e allegati

**50. [CRITICA] Vuoi vietare il download ordinario degli allegati e consentirne solo la visualizzazione controllata?**

*Perché serve chiarirlo: Un download crea copie persistenti sul computer dell'operatore che il sistema non può più eliminare.*

**Indicazione tecnica attuale: Consiglio SÌ: il download ordinario dovrebbe essere vietato; l'unica copia persistente sarebbe l'export d'emergenza.**

**RISPOSTA: SÌ, il download ordinario dovrebbe essere vietato; l'unica copia persistente sarebbe l'export d'emergenza. Questo è anche un concetto di sicurezza informatica a tutela dell'operatore.**

.....

**51. [ALTA] Vuoi disabilitare stampa e funzioni di download della pagina, pur sapendo che non possiamo impedire screenshot o fotografie dello schermo?**

*Perché serve chiarirlo: Sono barriere utili contro copie accidentali, non protezioni assolute contro un operatore malevolo.*

**RISPOSTA: Sì, voglio che tutte le funzionalità che impediscano questo genere di attività devono essere attuate.**

.....

**52. [ALTA] Vuoi disabilitare il copia/incolla del testo della segnalazione?**

*Perché serve chiarirlo: Riduce copie accidentali, ma può rendere più difficile lavorare. Un utente autorizzato può comunque trascrivere o fotografare il contenuto.*

**RISPOSTA: Sì, voglio che venga disabilitato il copia e incolla.**

.....

**53. [CRITICA] Gli allegati devono essere aperti solo in un visualizzatore interno/sandboxato e mai inviati all'applicazione predefinita del sistema operativo?**

*Perché serve chiarirlo: Aprire un PDF nel lettore locale può creare cache, file temporanei e superficie di attacco esterna alla piattaforma.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì, assicurati di utilizzare best practice in merito. La sicurezza informatica viene prima di tutto.**

.....

**54. [CRITICA] Possiamo produrre una copia di visualizzazione sanitizzata mantenendo separatamente l'originale cifrato?**

*Perché serve chiarirlo: È un buon compromesso tra sicurezza dell'operatore e preservazione dell'evidenza originale.*

**Indicazione tecnica attuale: Io lo consiglierei.**

**RISPOSTA: Non chiaro**

.....

**55. [CRITICA] Durante una sessione OPEN, testo e allegati possono esistere temporaneamente nella memoria del server oppure vuoi che la decifratura avvenga solo sul dispositivo dell'operatore?**

*Perché serve chiarirlo: La seconda soluzione riduce il valore di una compromissione del server ma rende l'architettura più complessa.*

**RISPOSTA: Scegli la soluzione più sicura in termini di sicurezza informatica**

**56. [CRITICA] Le pagine del ticket devono usare una politica "no-store" e non salvare contenuti in cache browser, localStorage, IndexedDB o service worker?**

*Perché serve chiarirlo: Evita che il contenuto resti sul dispositivo dopo la sessione.*

**Indicazione tecnica attuale: Consiglio SÌ senza eccezioni.**

**RISPOSTA: SÌ senza eccezioni.**

## 9. Audit log e responsabilità degli accessi

**57. [CRITICA] Confermi che l'audit log deve essere append-only/tamper-evident e separato dal database dei report?**

*Perché serve chiarirlo: Un amministratore dell'applicazione non dovrebbe poter cancellare le tracce dei propri accessi.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Si**

**58. [CRITICA] Quali eventi vuoi registrare obbligatoriamente?**

*Perché serve chiarirlo: Propongo: submission ricevuta, claim, prima apertura, allegato visualizzato, interruzione, richiesta riapertura + motivo, riapertura, export, risposta inviata, distruzione chiave, cancellazione completata.*

**Indicazione tecnica attuale: Puoi approvare l'elenco o modificarlo.**

**RISPOSTA: Approvo l'elenco che hai proposto.**

**59. [CRITICA] Vuoi registrare l'identità reale dell'operatore in ogni evento?**

*Perché serve chiarirlo: Gli operatori non sono anonimi: associare azioni a una persona/account è fondamentale per accountability.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Si**

**60. [ALTA] Vuoi registrare anche IP/postazione dell'operatore?**

*Perché serve chiarirlo: Può aiutare a rilevare accessi anomali. È diverso dal segnalante, che deve restare anonimo.*

**RISPOSTA: Si**

**61. [ALTA] Per quanto tempo devono essere conservati gli audit log dopo la distruzione del report?**

*Perché serve chiarirlo: I log non contengono il contenuto, ma possono comunque essere sensibili e devono avere una retention definita.*

**RISPOSTA: I log devono essere conservati per un anno dalla loro generazione**

**62. [ALTA] Chi può consultare gli audit log?**

*Perché serve chiarirlo: Separare il ruolo di operatore dal ruolo di audit/sicurezza riduce conflitti di interesse.*

**RISPOSTA: Solo la figura dell'amministratore, figura che per altro non ti avevo detto che deve essere creata.**

.....

**63. [ALTA] Le motivazioni testuali di riapertura/export devono essere considerate parte del log permanente?**

*Perché serve chiarirlo: Sono necessarie per accountability, ma non devono contenere dettagli del report.*

**Indicazione tecnica attuale: Consiglio SÌ con istruzioni forti a non copiare informazioni della segnalazione.**

**RISPOSTA: SÌ con istruzioni forti a non copiare informazioni della segnalazione.**

.....

**64. [ALTA] Vuoi registrare anche accessi e modifiche alle configurazioni di sicurezza del sistema?**

*Perché serve chiarirlo: Un cambio di retention, chiavi o logging può avere lo stesso impatto di un accesso al contenuto.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Si**

.....

## **10. Cifratura, chiavi, storage, cancellazione e backup**

**65. [CRITICA] Confermi che ogni segnalazione deve avere una chiave di cifratura indipendente?**

*Perché serve chiarirlo: Permette di distruggere un singolo ticket senza compromettere o dover ruotare le chiavi degli altri.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Si**

.....

**66. [ALTA] Vuoi che testo e tutti gli allegati dello stesso ticket siano protetti dalla stessa DEK oppure da chiavi separate derivate per ciascun oggetto?**

*Perché serve chiarirlo: Chiavi separate/derivate riducono il blast radius e consentono policy più precise, ma aumentano complessità.*

**RISPOSTA: La chiave deve esistere per ticket e, per tanto, deve poter contenere testo e allegati.**

.....

**67. [CRITICA] Dove deve essere custodita la chiave che permette di sbloccare le DEK dei ticket?**

*Perché serve chiarirlo: Questa è una delle decisioni più importanti: stessa macchina, servizio chiavi separato, HSM, o componente lato operatore.*

**Indicazione tecnica attuale: Non fisserei ancora la tecnologia prima di sapere contro quali amministratori vuoi proteggerti.**

**RISPOSTA: Dovremmo pensare alla soluzione migliore per garantire l'impossibilità di abusi da parte degli amministratori e/o operatori.**

.....

**68. [CRITICA] Dopo "Invia risposta", confermi che la DEK del report deve essere distrutta prima possibile e non recuperabile da backup?**

*Perché serve chiarirlo: È il meccanismo principale di cryptographic erase.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Si**

.....

**69. [CRITICA] Accetti che la cancellazione logica dei blob possa avvenire subito dopo, purché la distruzione della chiave li renda già illeggibili?**

*Perché serve chiarirlo: La rimozione fisica immediata da filesystem/repliche può non essere atomica; la distruzione chiave può rendere il contenuto irrecuperabile prima.*

**Indicazione tecnica attuale: È il modello che consiglio.**

**RISPOSTA: Sì**

.....

**70. [CRITICA] I backup possono contenere ciphertext dei report purché NON contengano chiavi che permettano di decifrare report già distrutti?**

*Perché serve chiarirlo: Questa scelta rende compatibile disaster recovery e cryptographic erase.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Non chiaro**

.....

**71. [CRITICA] Vuoi evitare completamente backup delle chiavi per-ticket, accettando che un guasto del key store possa rendere irrimediabilmente persi report non ancora processati?**

*Perché serve chiarirlo: È il trade-off tra disponibilità e cancellazione garantita. Backup delle chiavi possono far "resuscitare" dati cancellati.*

**RISPOSTA: Sì, non deve esistere uno strumento di backup.**

.....

**72. [CRITICA] Se invece serve una forma di recovery del key store, accetti un meccanismo che preservi le chiavi dei soli ticket ancora attivi ma renda impossibile recuperare quelle distrutte?**

*Perché serve chiarirlo: È più complesso ma può bilanciare disponibilità e cancellazione.*

**RISPOSTA: Non deve esistere uno strumento di backup.**

.....

**73. [CRITICA] Vuoi che la risposta "Invia risposta" fallisca e NON cancelli nulla se la Response Note non è stata cifrata e salvata correttamente?**

*Perché serve chiarirlo: Evita di distruggere il report senza lasciare al segnalante la risposta promessa.*

**Indicazione tecnica attuale: Consiglio SÌ: finalizzazione transazionale/fail-safe.**

**RISPOSTA: SÌ: finalizzazione transazionale/fail-safe.**

.....

**74. [ALTA] Se la cancellazione fisica dei blob fallisce dopo la distruzione chiave, il sistema deve considerare il ticket comunque irrecuperabile ma continuare a tentare la rimozione e loggare l'anomalia?**

*Perché serve chiarirlo: È il comportamento realistico in storage distribuiti.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì e se il problema dovesse persistere allora dovrebbe arrivare una segnalazione di anomalia all'amministratore.**

.....

**75. [ALTA] Vuoi minimizzare anche i metadati non cifrati (timestamp esatti, dimensioni file, conteggio allegati) oppure la priorità è solo il contenuto?**

*Perché serve chiarirlo: Anche senza testo, metadata molto precisi possono aiutare correlazioni temporali.*

**RISPOSTA:** I file devono essere gestiti per come li riceviamo e non devono essere modificati. Quando caricheranno un file a livello grafico gli verrà comunicato di avere l'accortezza di eliminare i meta dati suggerendo strumenti adeguati in merito, ma non saremo noi a modificarli.

.....

## 11. Response Note

**76. [CRITICA] La Response Note deve essere esclusivamente testo semplice, senza HTML, immagini, allegati o formattazione attiva?**

*Perché serve chiarirlo: Riduce XSS, tracking, contenuti remoti e complessità.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA:** Sì

.....

**77. [MEDIA] Vuoi imporre un limite massimo di caratteri anche alla risposta?**

*Perché serve chiarirlo: Evita abusi e rende il formato prevedibile.*

**RISPOSTA:** Massimo 5.000 caratteri

.....

**78. [ALTA] La risposta può contenere URL testuali?**

*Perché serve chiarirlo: Un link può portare il segnalante fuori dall'ambiente anonimo e, se cliccato, creare metadata. Possiamo mostrarlo come testo non cliccabile o consentire link con avviso.*

**RISPOSTA:** No, non devono essere presenti link e al fine di prevedere ciò dobbiamo eliminare la possibilità del caricamento automatico dei link. Dobbiamo inibire il testo rendendolo semplice test così da evitare anche problemi di sicurezza informatica.

.....

**79. [CRITICA] L'operatore può salvare una bozza della risposta prima dell'invio?**

*Perché serve chiarirlo: Una bozza può contenere parti copiate dalla segnalazione e diventare una nuova copia persistente.*

**Indicazione tecnica attuale: Io eviterei bozze server-side nella baseline; la risposta viene composta nella sessione e inviata una volta.**

**RISPOSTA:** No

.....

**80. [ALTA] Dopo l'invio, nessun operatore deve poter modificare la Response Note?**

*Perché serve chiarirlo: Una risposta immutabile semplifica audit e impedisce modifiche retroattive.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA:** Sì

.....

**81. [CRITICA] La Response Note deve essere cifrata in modo che il server/storage non possa leggerla senza il recovery secret del segnalante?**

*Perché serve chiarirlo: Aumenta privacy anche dopo la distruzione del report originale.*

**Indicazione tecnica attuale: È il modello che preferisco, ma richiede definire bene la crittografia del recupero.**

**RISPOSTA:** Se tecnicamente possibile allora sì

.....



## 12. Export d'emergenza e integrità del materiale

**82. [CRITICA] Chi può avviare un export d'emergenza: qualsiasi operatore che ha il ticket OPEN oppure solo operatori con un privilegio speciale?**

*Perché serve chiarirlo: L'export è l'unico meccanismo che crea deliberatamente una copia persistente del report.*

**RISPOSTA: Qualsiasi operatore che ha il ticket OPEN**

.....

**83. [CRITICA] L'export deve richiedere l'approvazione di un secondo operatore/supervisore?**

*Perché serve chiarirlo: Una doppia autorizzazione riduce fortemente il rischio di esfiltrazione abusiva ma può rallentare urgenze reali.*

**RISPOSTA: L'export deve avvenire previo captcha e doppia autenticazione dell'operatore. Inoltre, oltre ad essere loggata come attività, deve arrivare una segnalazione all'amministratore.**

.....

**84. [CRITICA] Confermi che l'operatore deve inserire una motivazione obbligatoria prima dell'export?**

*Perché serve chiarirlo: Serve a rendere l'operazione eccezionale e auditabile.*

**Indicazione tecnica attuale: Attualmente lo considero approvato.**

**RISPOSTA: Sì, deve essere testuale con una capienza massima di 1.000 caratteri.**

.....

**85. [ALTA] La procedura guidata deve richiedere una seconda autenticazione forte immediatamente prima della generazione?**

*Perché serve chiarirlo: Protegge contro sessioni lasciate aperte o account appena compromessi.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Non chiaro, di quale procedura guidata parli?**

.....

**86. [CRITICA] L'archivio deve contenere il testo originale e tutti gli allegati originali byte-per-byte?**

*Perché serve chiarirlo: È ciò che serve se l'obiettivo è preservare integralmente ciò che il sistema ha ricevuto.*

**Indicazione tecnica attuale: Da quanto hai scritto direi SÌ.**

**RISPOSTA: Sì, assicurando tutte le best practice di sicurezza informatica.**

.....

**87. [ALTA] Vuoi includere nel manifest anche timestamp di ricezione, elenco file, dimensioni e hash crittografici?**

*Perché serve chiarirlo: Gli hash permettono di dimostrare successivamente che il materiale esportato non è stato modificato.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì**

.....

**88. [ALTA] Vuoi che il manifest sia firmato digitalmente dall'istanza/organizzazione?**

*Perché serve chiarirlo: Una firma consente di verificare provenienza e integrità del manifest, ma introduce gestione di una chiave di firma.*

**RISPOSTA: Sì**

.....

**89. [CRITICA] Il file finale deve essere sempre cifrato con una chiave pubblica preconfigurata, invece di usare una semplice password ZIP?**

*Perché serve chiarirlo: Una password può essere debole, riutilizzata o condivisa male. La cifratura a chiave pubblica è più robusta.*

**Indicazione tecnica attuale: Consiglio fortemente cifratura a chiave pubblica/strumento standard, non ZIP password tradizionale.**

**RISPOSTA: Assolutamente sì, si deve utilizzare una chiave pubblica preconfigurata.**

#### **90. [CRITICA] A chi deve appartenere la chiave di destinazione dell'export?**

*Perché serve chiarirlo: Possibili modelli: chiave dell'organizzazione, chiave di un responsabile sicurezza, chiave specifica delle autorità inserita al momento. Ogni opzione cambia la catena di custodia.*

**RISPOSTA: Chiave dell'organizzazione**

#### **91. [ALTA] Il sistema può consentire il download dell'archivio cifrato sul computer dell'operatore oppure vuoi evitare che anche il file cifrato resti lì?**

*Perché serve chiarirlo: Scaricare crea una copia fuori dal controllo applicativo, anche se cifrata.*

**RISPOSTA: Il sistema deve permettere di scaricare l'archivio cifrato**

#### **92. [CRITICA] Dopo un export, confermi che il report interno deve comunque essere distrutto normalmente quando viene inviata la Response Note?**

*Perché serve chiarirlo: L'export non dovrebbe trasformare la piattaforma in archivio permanente; la copia eccezionale vive fuori dal normale lifecycle.*

**Indicazione tecnica attuale: La tua indicazione precedente sembra SÌ; confermala.**

**RISPOSTA: Sì**

#### **93. [ALTA] L'audit log deve conservare l'hash dell'archivio esportato, ma non una copia dell'archivio?**

*Perché serve chiarirlo: Permette di verificare l'artefatto senza mantenere duplicati del contenuto sensibile.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì**

#### **94. [ALTA] Vuoi che il formato di export sia progettato anche per preservare integrità utile a successive attività investigative, senza promettere "valore probatorio" universale?**

*Perché serve chiarirlo: Le regole legali cambiano per giurisdizione; possiamo garantire integrità tecnica e tracciabilità, non ammissibilità giuridica automatica.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì**

## **13. Tempi di conservazione e casi non conclusi**

#### **95. [CRITICA] Quanto tempo può restare memorizzata una segnalazione SEALED che nessun operatore prende in carico?**

*Perché serve chiarirlo: Senza una scadenza, contenuti estremamente sensibili potrebbero accumularsi indefinitamente.*

**RISPOSTA: Finché non viene gestita la pratica. Dal momento che nel caso in cui ci fosse un attacco che ci inonda di richieste allora dovrebbe esistere anche un modo per selezionare ed eliminare segnalazioni ancora sealed.**

.....

**96. [ALTA] Quanto tempo può restare CLAIMED ma non OPEN prima di tornare disponibile o essere marcata come anomala?**

*Perché serve chiarirlo: Serve a evitare ticket bloccati da un operatore che non li processa.*

**RISPOSTA: Prima di tornare disponibile può restare claimed fino alla mezzanotte del giorno di apertura.**

.....

**97. [ALTA] Quanto tempo può rimanere INTERRUPTED prima di richiedere un intervento amministrativo o una decisione diversa?**

*Perché serve chiarirlo: Una sessione interrotta non deve diventare un modo per conservare indefinitamente il report.*

**RISPOSTA: Non deve esserci una scadenza per interrupted**

.....

**98. [CRITICA] Che cosa succede se l'operatore conclude che la segnalazione è spam, vuota o non gestibile?**

*Perché serve chiarirlo: Dobbiamo decidere se deve comunque inviare una Response Note minima e distruggere il contenuto, oppure se esiste una chiusura senza risposta.*

**RISPOSTA: In questi casi deve poter eliminare completamente la segnalazione andando a dare un motivo in merito. Deve mantenersi loggato l'identificativo iniziale del tiket e la motivazione di chiusura da parte dell'operatore.**

.....

**99. [CRITICA] Se nessuna risposta viene mai prodotta entro il periodo massimo, il report deve essere automaticamente distrutto?**

*Perché serve chiarirlo: È la soluzione più coerente con minimizzazione dei dati, ma può comportare perdita di una segnalazione non gestita.*

**RISPOSTA: Dopo 7 giorni che il report è stato ricevuto deve essere contraddistinguibile dagli altri come report in ritardo. Dopo 30 giorni deve essere contrassegnato come urgente.**

.....

**100. [CRITICA] Quanto tempo deve restare disponibile la Response Note dopo che il report è stato distrutto?**

*Perché serve chiarirlo: È l'unico contenuto che deve sopravvivere alla finalizzazione e serve una retention precisa.*

**RISPOSTA: 3 giorni dalla prima apertura della Response Note.**

.....

**101. [ALTA] Se la Response Note scade senza essere letta, deve essere distrutta automaticamente?**

*Perché serve chiarirlo: Evita conservazione indefinita di risposte che possono comunque contenere informazioni sensibili.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: La response note non può scadere senza essere letta perché il countdown parte dalla prima apertura e dura 3 giorni.**

.....

## **14. Ambiente operativo e amministrazione del sistema**

**102. [CRITICA] Ogni installazione deve essere dedicata a una singola organizzazione oppure prevedi fin dall'inizio un servizio centrale multi-organizzazione?**

*Perché serve chiarirlo: Il multi-tenant aumenta molto il rischio e la complessità di isolamento. Un'istanza per organizzazione è più semplice da proteggere.*

**Indicazione tecnica attuale: Per la baseline consiglio una singola organizzazione per istanza.**

**RISPOSTA: Singola organizzazione per istanza.**

.....

**103. [CRITICA] Gli operatori useranno normali computer di lavoro oppure possiamo richiedere una postazione/browser dedicato e controllato?**

*Perché serve chiarirlo: Browser extension, malware, sincronizzazione cloud e cache del dispositivo possono vanificare parte delle garanzie applicative.*

**RISPOSTA: Possiamo richiedere una postazione dedicata ma dobbiamo accettare il fatto che possano essere utilizzati anche computer di lavoro normali.**

.....

**104. [ALTA] L'area operatori deve essere raggiungibile da Internet oppure solo tramite rete privata/VPN/Onion Service dedicato?**

*Perché serve chiarirlo: Ridurre l'esposizione dell'interfaccia operatori diminuisce il rischio di attacchi agli account.*

**RISPOSTA: Deve essere raggiungibile da Internet**

.....

**105. [CRITICA] Vuoi separare tecnicamente il ruolo "amministratore del sistema" dal ruolo "operatore che legge le segnalazioni"?**

*Perché serve chiarirlo: La separazione dei compiti evita che una sola persona abbia controllo completo su infrastruttura, contenuti e audit.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì, il ruolo amministratore del sistema si occupa anche di controllare gli operatori.**

.....

**106. [ALTA] Vuoi che anche l'accesso agli audit log sia un ruolo separato?**

*Perché serve chiarirlo: Impedisce a chi processa i report di alterare/controllare autonomamente le tracce delle proprie azioni.*

**RISPOSTA: Gli audit log devono poter essere accessibili dal ruolo amministratore ma non dagli operatori.**

.....

**107. [ALTA] Accetti che aggiornamenti, crash reporting e telemetria siano completamente self-hosted o disabilitati?**

*Perché serve chiarirlo: È coerente con la promessa di non inviare informazioni operative o contenuti a terzi.*

**Indicazione tecnica attuale: Consiglio SÌ.**

**RISPOSTA: Sì**

.....

## 15. Riepilogo libero e punti non compresi

**Usa questo spazio per:**

- indicare domande che hai segnato come NON CHIARO;
- correggere una decisione che avevamo già considerato approvata;
- aggiungere un rischio o uno scenario che ritieni importante e che non compare nel documento;
- specificare priorità personali (es. "preferisco perdere un ticket piuttosto che rischiare che resti recuperabile").

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....

.....